Verificação adversarial com 3 agentes para reduzir falsos positivos na detecção de vulnerabilidades

Auditoria de Belozerov et al. (EMSE, 2026) e teste de um pipeline com modelos abertos

Apresentador 1 · Apresentador 2 · Apresentador 3 · Apresentador 4

Projeto da disciplina TAES · Centro de Informática, UFPE · novembro de 2026

Centro de Informática
UFPE

Roteiro

01

Contexto e auditoria

Apresentador 1
~8 min

O artigo, o que ele mede e o que a auditoria encontrou

02

Proposta e método

Apresentador 2
~9 min

Os 3 agentes, as 6 configurações, o gabarito e as métricas

03

Resultados

Apresentador 3
~11 min

O que o verificador faz com os achados, hipóteses e variância

04

Análises e conclusão

Apresentador 4
~10 min

Modelos do artigo, peso do modelo, correção e limites

Mensagem central: o verificador corta falsos alarmes, mas corta issues reais junto, e não separa melhor o real do falso.

O artigo analisado

Belozerov, Barclay e Sami (2026). *Secure coding with AI – from detection to repair*. EMSE 31:93.

Pergunta do artigo: LLMs conseguem detectar e corrigir vulnerabilidades em código que veio de conversas reais com o ChatGPT?

2.315
trechos de C, C++ e C# do DevGPT

→

4
scanners estáticos: Snyk, Semgrep, Flawfinder e Cppcheck

→

114
arquivos: 48 com issue real e 66 negativos

→

56 + 85
revisão manual: 56 issues reais e 85 alertas julgados seguros

→

~80%
de "acurácia" na detecção (e ~77% na correção) com GPT-4.1, GPT-5 e Opus 4.1

Nosso trabalho: auditar esses números com os dados dos autores e medir o que o artigo não mede: **os falsos positivos**.

O que o artigo mede, e o que não mede

~80%

de “acurácia” = issues detectadas ÷ 56. É recall relativo ao gabarito dos scanners.

66 de 114

arquivos são negativos, e mesmo assim precisão e falso positivo nunca foram medidos.

4,8 a 6,5

CWEs citadas por arquivo, contra ~1,2 issue real por arquivo positivo.

98,5 a 100%

dos arquivos negativos recebem ao menos uma CWE; 35% a 42% dos 85 falsos alarmes são citados.

O prompt original manda o modelo **“encontrar problemas de segurança”**. Cada modelo rodou **uma única vez**, sem intervalo de confiança.

Auditoria: o que não bate no artigo

REFUTADO

"GPT-5 corrigiu todas as 44 issues que detectou": detectou 44 e corrigiu 44, mas não as mesmas.

REFUTADO

Finding 15, "todos vão melhor em código do usuário": falso para GPT-4.1 e Opus 4.1.

NÃO SIGNIFICATIVO

A "melhora" de 2024 para 2025: McNemar exato nas 28 issues comuns, p = 0,065 a 0,267.

TABELAS COM ERROS

Tabela 11 diverge do texto (16/16 × 17/15); 3 de 6 células das Tabelas 17–18; CWEs trocadas na 14.

INCONSISTÊNCIAS

"3 scanners" no texto, 4 no estudo; "reescaneamento" no resumo, mas é trabalho futuro.

GABARITO MUDOU

Entre 2024 e 2025, no mesmo snapshot: 4 issues saíram e 2 mudaram de metadados.

Recontagem com os dados dos autores, sem LLM. Detalhes: pipeline/results/auditoria_artigo.md

Pergunta

Um verificador adversarial reduz falsos positivos sem perder detecção?

Medimos precisão **e** recall usando só os rótulos dos autores: 56 issues reais e 85 falsos alarmes conhecidos.

H1 · C3 × B1: o verificador reduz os falsos alarmes perdendo no máximo 5 p.p. de recall

H2 · B1 × B0: o prompt neutro (aceita "nenhuma vulnerabilidade") já reduz falsos alarmes

H3 · C3 × C2: verificar sem ver a correção rejeita mais falsos alarmes

H4 · C1/C3 × curva do B1: o verificador vale mais que um corte por confiança

H5 · C3 × C3-mf: um verificador de outra família remove mais falsos positivos

E1 · C3 × modelos do artigo (exploratória)

H1 a H3 são confirmatórias; critérios fixados antes dos resultados.

Proposta e método

Bloco 2 · Apresentador 2

≈ 9 minutos

Neste bloco

1. Os 3 agentes
2. As 6 configurações
3. Dados e gabarito
4. Correspondência e métricas
5. Modelos e infraestrutura

Três papéis: detectar, corrigir, verificar

A1 **Detector**

Lê o código com linhas numeradas e lista achados: CWE, linhas, fonte → sink, gatilho e confiança. "Nenhuma vulnerabilidade" é resposta aceitável.

Modelo: **qwen2.5-coder 14B**

A2 **Corretor**

Gera um patch mínimo para cada achado e explica como o gatilho fica bloqueado, preservando o comportamento.

Modelo: **qwen2.5-coder 14B**

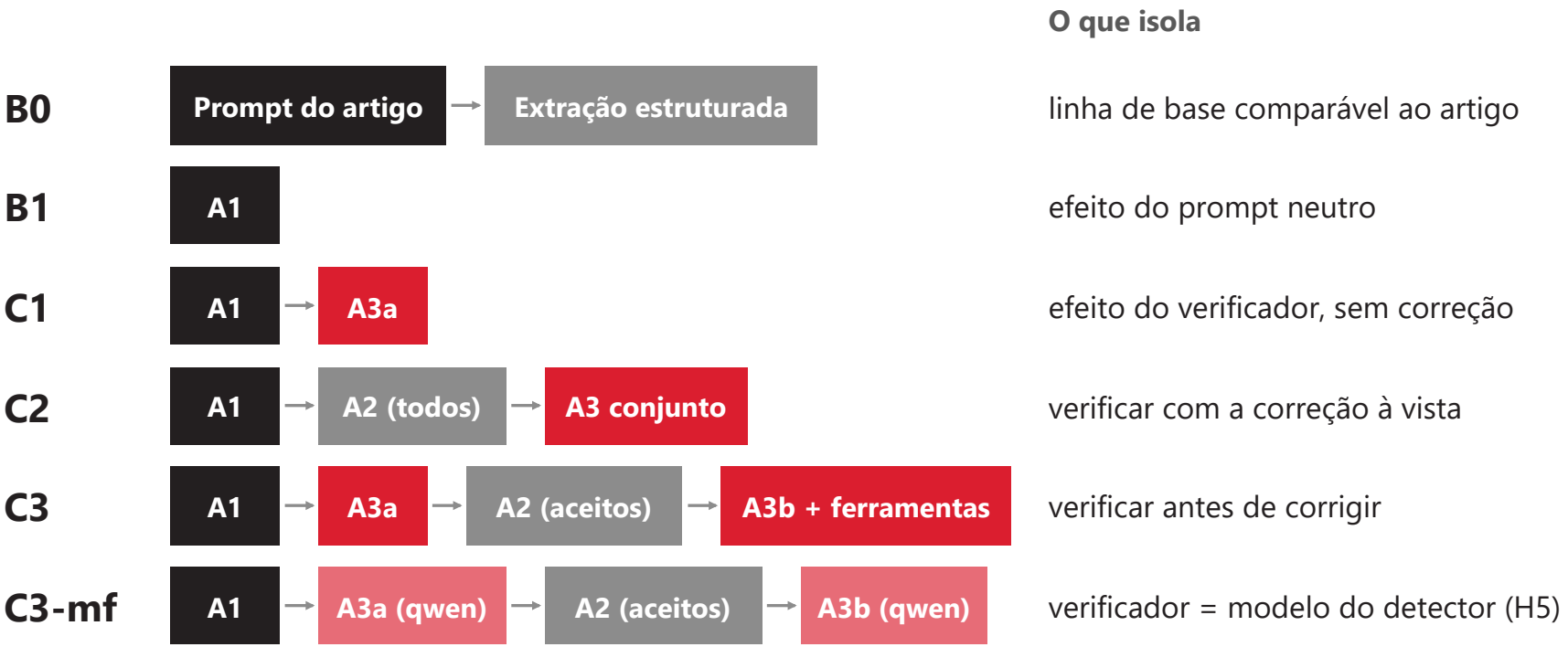
A3 **Verificador adversarial**

A3a tenta refutar o achado (padrão: refutado), sem ver a correção. A3b julga a correção com compilação e scanners.

Modelo: **gpt-oss 20B**

Um achado por chamada no A3 · nenhum agente vê o gabarito, a saída dos scanners ou a confiança do A1 · ferramentas só no A3b

Seis configurações, o mesmo detector



A saída do A1 é gerada uma vez e reaproveitada: as diferenças vêm só das etapas seguintes.

Gabarito: só os rótulos dos autores

114 arquivos



141 locais rotulados pelos autores



Falso alarme conhecido: alerta de scanner que os autores examinaram e julgaram seguro (ex.: um *printf* com formato constante).

Três classes de achado

Issue real	casa com uma das 56: conta no recall
Falso alarme conhecido	casa com um dos 85: conta como falso positivo
Fora do gabarito	não casa com nada: não é julgado (sem anotador), só entra nas descritivas

Sem anotador humano: a **precisão** é calculada só no conjunto rotulado (141 locais). Os achados fora do gabarito ficam como limite superior e inferior.

Como contamos acertos

Regra de correspondência (estrita)

1. Mesmo arquivo
2. Até 3 linhas de distância
3. CWE compatível: igual, ancestral ou descendente na CWE-1000, ou da mesma família

Cada issue conta no máximo uma vez.

Sensibilidade S1: só a linha ±3, sem checar a CWE.

Métricas

Recall	issues reais acusadas ÷ 56
Falsos alarmes	falsos alarmes acusados ÷ 85
Precisão	reais ÷ (reais + falsos alarmes)
Também	F1, F0,5 e MCC

Estatística

- IC de 95% por bootstrap sobre arquivos (2.000 réplicas)
- McNemar exato, Q de Cochran, correção de Holm
- H1 a H3 confirmatórias; o resto é exploratório

Modelos abertos, custo zero

14B

qwen2.5-coder (Q4_K_M): detector e corretor

20B

gpt-oss (MXFP4, raciocínio médio): verificador, de outra família

2 × T4

GPUs gratuitas do **Kaggle**, modelos servidos pelo Ollama

R$ 0

17,6 h de GPU nas execuções, mais ~3,4 h de piloto e ajustes

Controle

- temperature = 0 e seed = 0 na execução principal
- até 4 achados por arquivo; achados repetidos removidos
- verificador e corretor não veem a confiança do A1 nem os rótulos

Reprodutibilidade

- prompts congelados com hash antes da execução
- piloto de 10 arquivos: a1_v1 → a1_v2 (S4 refaz tudo nos outros 104)
- 158 testes automáticos; cada decisão no DIARIO.md

Resultados

Bloco 3 · Apresentador 3

≈ 11 minutos

Neste bloco

1. Resultado principal
2. O que o verificador remove
3. Verificador × corte de confiança
4. Hipóteses e variância
5. Ruído, custo e balanço

RESULTADO

em uma frase

85%

dos falsos alarmes removidos

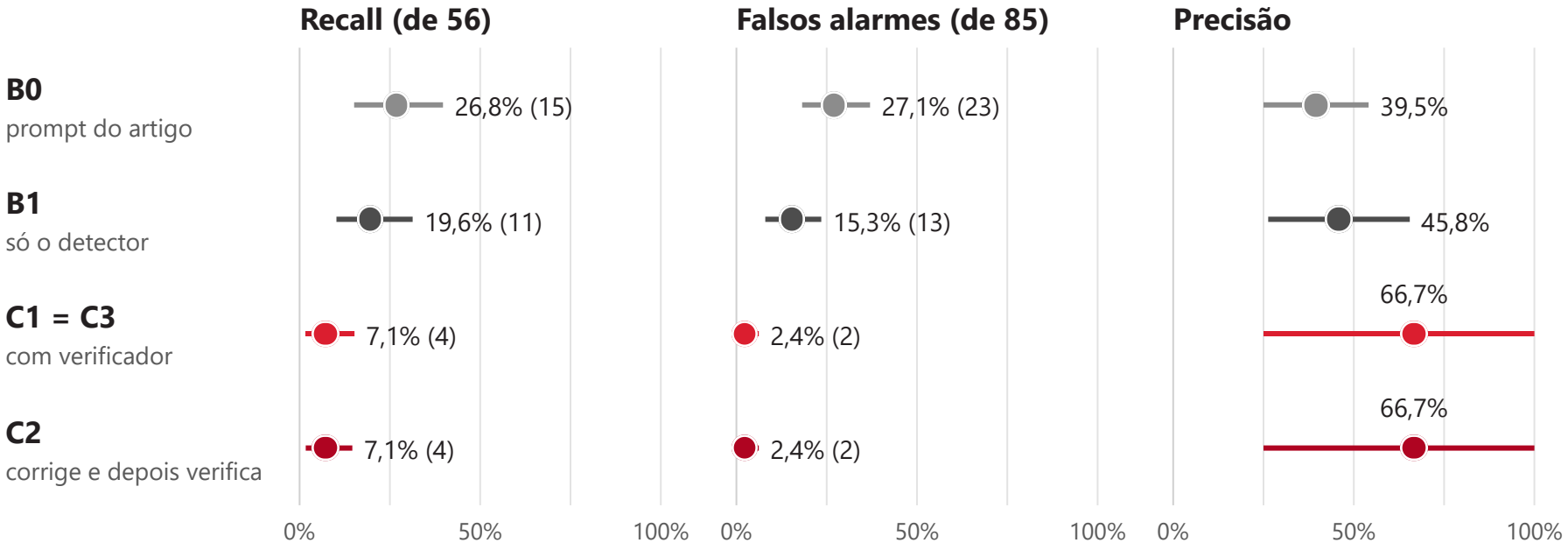
e 64% das issues reais perdidas

O verificador adversarial cortou os falsos alarmes, e cortou as issues reais junto.

A H1 admitia perder no máximo 5 p.p. de recall. Perdemos **12,5 p.p.**, e o ganho de precisão não é significativo.

Resultado principal (regra estrita)

114 arquivos · ponto = estimativa; linha = IC de 95% (bootstrap sobre arquivos)



C1 e C3 aceitam o mesmo conjunto. C3-mf (verificador qwen): nenhum achado aceito (0 de 56, 0 de 85).

Remove muito, discrimina pouco

● mantido pelo verificador ○ removido pelo verificador

Issues reais que o detector acusava



mantém 4 (36%)

Falsos alarmes conhecidos que o detector acusava



mantém 2 (15%)

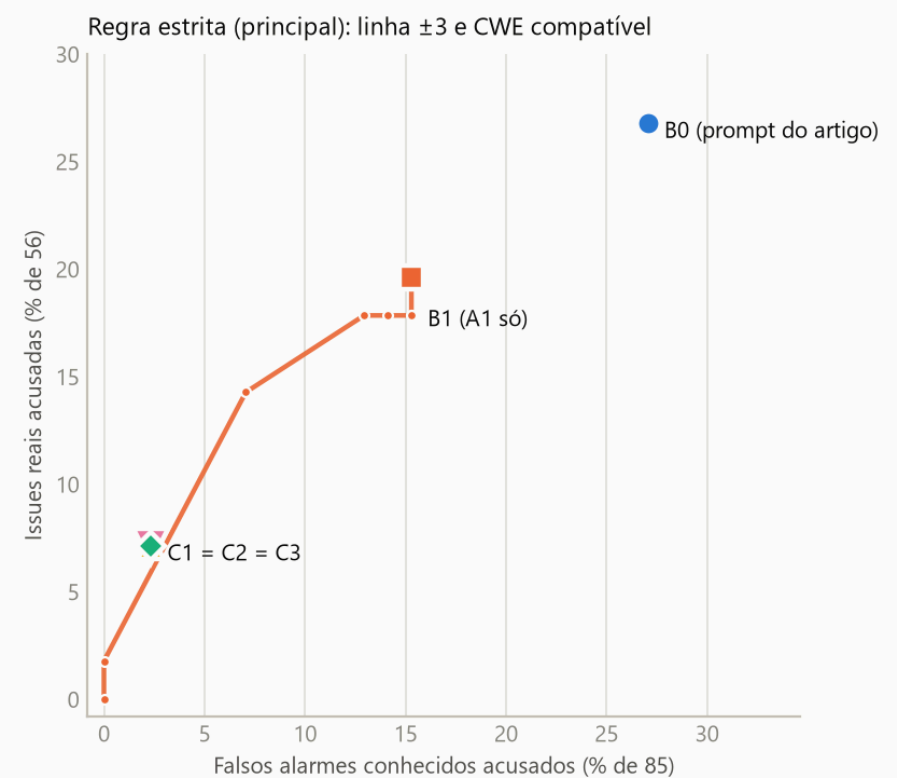
Fisher exato: p = 0,36

Não dá para distinguir isso de um filtro que rejeita quase tudo. Só pela linha (S1): mantém 16% dos reais e 10% dos falsos.

Contraste: calibração

Sobre os achados dos scanners, o mesmo verificador confirmou 39% dos reais (22/56) e 5% dos falsos (4/85), $p = 3 \times 10^{-7}$.

Verificador × corte de confiança (H4)



Linha laranja: o B1 aceitando só achados com confiança do A1 acima de um limiar (cada ponto é um limiar).

Com a taxa de falsos alarmes do C3 (2,4%):

1 de 56
melhor corte de confiança do B1

4 de 56
verificador (C1/C3)

H4 · EVIDÊNCIA FRACA

+5,4 p.p., mas com base em 4 contra 1 locais.

Hipóteses: o veredito

Diferenças A − B em p.p.; IC de 95% por bootstrap pareado por arquivo

	Comparação	O que medimos	Veredito
H1	C3 − B1	Recall −12,5 [−22,0; −4,7]; falsos alarmes −12,9 [−20,5; −6,1]; precisão +20,8 [−18,4; +58,6]	**Não confirmada:** recall cai mais que 5 p.p.
H2	B1 − B0	Falsos alarmes −11,8 [−20,2; −3,7]; recall −7,1 [−20,0; +4,9]; McNemar p = 0,013 (Holm 0,052)	**Apoiada, com ressalva:** 28% dos achados do B0 sem linha
H3	C3 − C2	Zero em tudo: os dois acusam os mesmos 2 falsos alarmes	**Não confirmada;** C3 só é mais barato
H4	C1/C3 × curva do B1	Na mesma taxa de falsos alarmes: 4/56 contra 1/56	**Evidência fraca** (+5,4 p.p.)
H5	C3 − C3-mf	O qwen como verificador refutou 229 de 229 achados	**Não apoiada;** teste degenerado (bloco 4)

Variância: a conclusão se repete

B1 e C3 repetidos 3 vezes com amostragem: detector com temperatura 0,7, verificador 1,0, seeds 1 a 3

Repetição	B1 recall	B1 falsos alarmes	C3 recall	C3 falsos alarmes	C3 precisão
var1	12,5%	14,1%	5,4%	2,4%	60,0%
var2	14,3%	17,6%	1,8%	4,7%	20,0%
var3	17,9%	15,3%	7,1%	3,5%	57,1%
Média ± dp	14,9 ± 2,7	15,7 ± 1,8	4,8 ± 2,7	3,5 ± 1,2	45,7 ± 22,3
Principal (T = 0)	19,6%	15,3%	7,1%	2,4%	66,7%

0 de 3

repetições cumprem o critério da H1

- falsos alarmes: −11,8 a −12,9 p.p. (IC abaixo de 0 nas três)
- recall: −7,1 a −12,5 p.p.
- precisão do C3: de 20% a 60%

O que se ganha e o que se paga

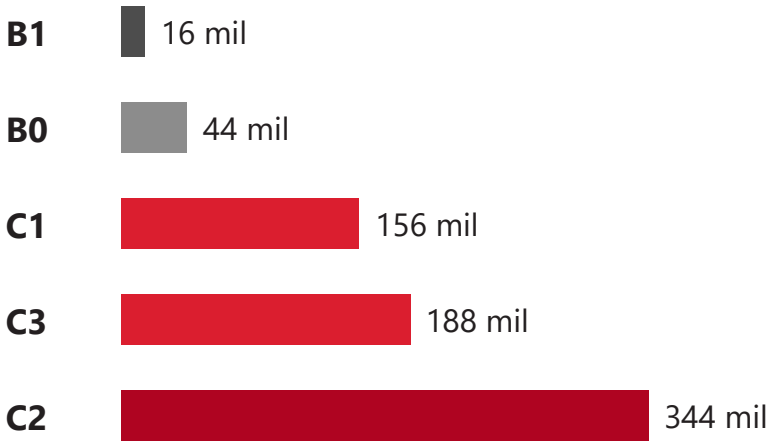
Menos ruído

B0	B1	C3
93,9%	**54,5%**	**9,1%**
arquivos negativos sinalizados		
328	**202**	**16**
achados fora do gabarito (não julgados)		

Não sabemos quantos dos removidos eram vulnerabilidades reais que os scanners não viram.

Mais custo

tokens por issue real acusada (milhares)



Segundos de chamada por arquivo: B1 23 · C1 54 · C3 72 · B0 158 · C2 197

A redução valeu a pena?

11 falsos alarmes conhecidos evitados × **7** issues reais perdidas

Compensa só se perder 1 vulnerabilidade custar menos que revisar **~1,6 alarme falso** (11 ÷ 7).

Em segurança, deixar passar uma vulnerabilidade costuma custar bem mais que revisar um alarme.

Métrica	B1	C3	Leitura
F1	27,5%	12,9%	−14,6 p.p. (IC < 0)
F0,5	36,2%	25,0%	também cai
MCC	0,06	0,12	IC inclui 0
Precisão	45,8%	66,7%	IC de 25% a 100%

O C3 só vence no Fβ se a precisão valer **mais de 3,6 vezes** o recall (β < 0,28).

Ganho claro: ruído. Arquivos negativos sinalizados: 54,5% → 9,1%.

Análises e conclusão

Bloco 4 · Apresentador 4

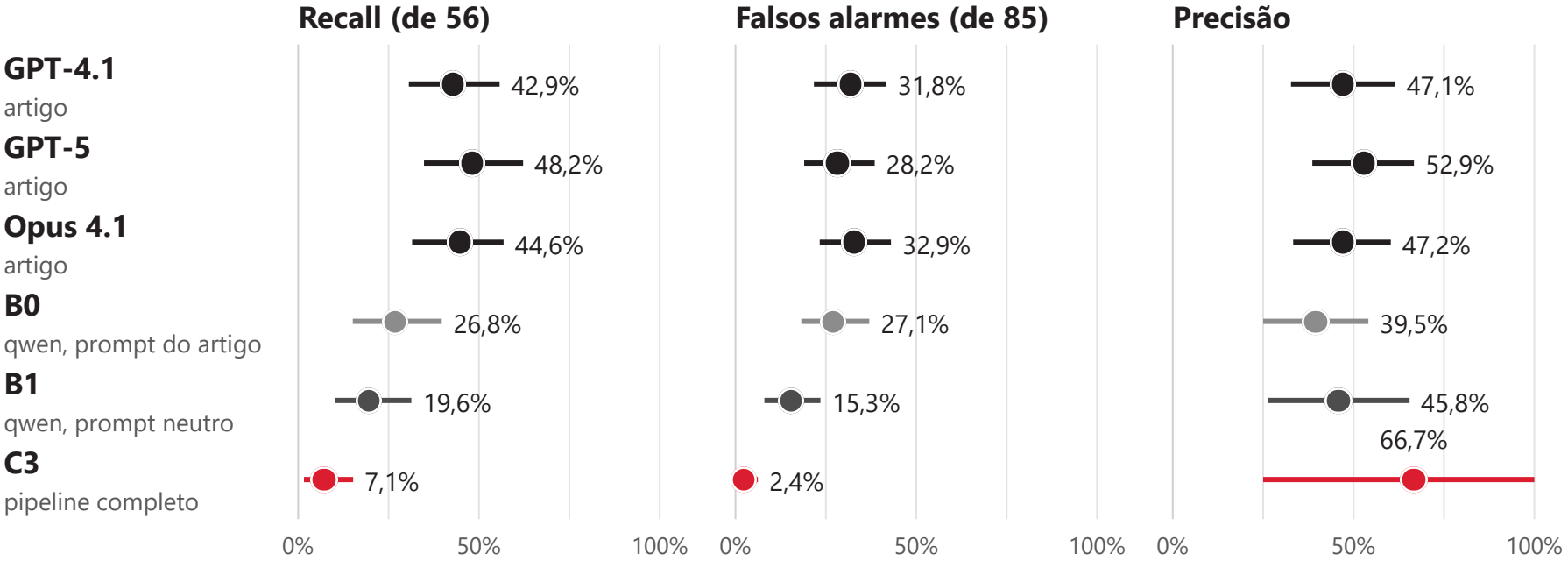
≈ 10 minutos

Neste bloco

1. Contra os modelos do artigo (E1)
2. O peso do modelo
3. H5 (C3-mf)
4. Correção com o mesmo juiz
5. Limites e conclusão

Contra os modelos do artigo (E1)

Mesmo extrator estruturado e mesma regra estrita para todos; 114 arquivos; análise exploratória



C3 − artigo: recall −36 a −41 p.p. e falsos alarmes −26 a −31 p.p. (IC exclui 0); precisão: IC de cerca de −30 a +57 p.p.

O peso do modelo

Comparação exploratória, feita depois dos resultados; os modelos do artigo nunca rodaram dentro do pipeline

Troca	Efeito
Detector: qwen 14B × GPT-4.1, GPT-5, Opus (mesmo prompt)	Recall **−16 a −21 p.p.**; falsos alarmes parecidos (−1 a −6 p.p., IC inclui 0)
Só a linha (sem CWE)	Os maiores apontam mais de tudo, com a **mesma precisão** (+0,5 a +2,8 p.p.)
Verificador: qwen 14B × gpt-oss 20B	Confirma **0%** × **10%** dos achados

O que se conclui

1. Os números absolutos dependem do modelo; o recall baixo é, em boa parte, efeito do detector pequeno.
2. O modelo maior não resolve o falso positivo: acusa 28% a 33% dos falsos alarmes, contra 27%.
3. O efeito do verificador depende de quem verifica: o mesmo prompt dá 10% ou 0% de confirmações.
4. Em nenhuma troca o verificador separou melhor o real do falso.

H5: o verificador do mesmo modelo refuta tudo

229 de 229

achados **refutados** pelo qwen como verificador (confiança 0,8 a 1,0)

23 de 229

achados **confirmados** pelo gpt-oss (10%) no C3

0 e 0

issues reais (de 56) e falsos alarmes (de 85) acusados pelo C3-mf

NÃO APOIADA · TESTE DEGENERADO

- C3 − C3-mf: falsos alarmes +2,4 p.p. [0,0; +6,2]; recall +7,1 p.p. [+1,6; +15,2]. O C3-mf “remove mais” só porque remove tudo.
- A comparação troca família **e** capacidade (14B sem raciocínio × 20B com raciocínio). Separar exigiria outra variante.

Correção, com o mesmo juiz (A3b)

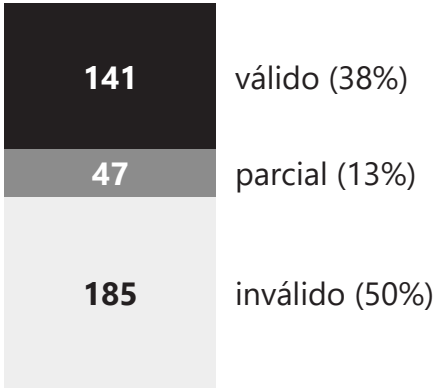
3 de 15

issues reais acusadas e corrigidas pelo **B0** (20%; 5,4% das 56)

0 de 4

no **C2** e no **C3** (taxa não informativa com 4 issues)

A3b nos 373 achados do B0



- O juiz concorda pouco com os autores: **κ = 0,28** contra "Was issue fixed" (0,42 se "parcial" conta).
- O B0 gera **um patch por arquivo**; C2 e C3, um por achado: a comparação não é um para um.
- Patches desnecessários (para falsos alarmes conhecidos): **14 no C2**, 2 no C3.
- **Sem evidência de que verificar antes de corrigir melhore a correção.**

Limites do estudo

Gabarito

Mistura riscos de padrão (strlen, printf) com falhas exploráveis; o verificador busca explorabilidade.

Tipo de falso alarme

Só falsos alarmes de scanner: alucinações livres do modelo ficam fora do gabarito.

Amostra pequena

56 reais e 85 falsos; o C3 acusa 4 e 2. Precisão do C3: IC de 25% a 100%.

Correspondência

A regra concorda pouco com o “detected” dos autores (κ de 0,08 a 0,27); S1 e S6 medem o efeito.

Modelos e execução

Modelos menores que os do artigo; execução única, com variância repetida só em B1 e C3.

Contaminação

DevGPT, artigo e dados são públicos; os modelos podem ter visto os rótulos.

Conclusão

O verificador adversarial desloca o ponto de operação, com menos alarmes e menos detecção, em vez de separar melhor o real do falso.

O que mostramos

- H1 não confirmada, também nas 3 repetições
- O verificador discrimina achados de scanner (39% × 5%), mas não os do detector (36% × 15%, p = 0,36)
- O artigo mede só recall relativo

Contribuições

- Auditoria dos números do artigo
- Pipeline reprodutível a custo zero
- Precisão e recall com os rótulos existentes

Próximos passos

- Anotador humano para os achados fora do gabarito
- Verificador mais forte; separar família de capacidade
- Detector maior, para errar menos a CWE

Muito obrigado!

Perguntas?

Apresentador 1
Apresentador 2
Apresentador 3
Apresentador 4

Materiais

- Relatório final: relatorio/RELATORIO.pdf
- Decisões e execuções: pipeline/DIARIO.md
- Código, prompts e resultados: pipeline/
- Artigo: Belozerov et al., EMSE 31:93 (2026)

Apêndice A · Sensibilidade

Variante (recall / falsos alarmes)	B0	B1	C1 = C3	C2
Principal (regra estrita)	26,8 / 27,1	19,6 / 15,3	7,1 / 2,4	7,1 / 2,4
S1: só linha ±3, sem CWE	67,9 / 44,7	55,4 / 34,1	8,9 / 3,5	8,9 / 3,5
S2: “uncertain” aceito	26,8 / 27,1	19,6 / 15,3	8,9 / 2,4	7,1 / 2,4
S3: só segurança (54 issues)	27,8 / 27,1	20,4 / 15,3	7,4 / 2,4	7,4 / 2,4
S4: 104 arquivos fora do piloto	25,5 / 25,3	19,1 / 13,9	8,5 / 2,5	8,5 / 2,5
S5: sem as 2 extrações falhas do B0	26,8 / 27,7	19,6 / 15,7	7,1 / 2,4	7,1 / 2,4
S6: arquivo + CWE, sem linha	42,9 / 40,0	28,6 / 23,5	8,9 / 4,7	8,9 / 3,5

Na S1, dos 31 locais reais e 29 falsos alarmes que o B1 acusava só pela linha, o verificador mantém 5 e 3 (16% e 10%).

Apêndice B · Custo por configuração

Config	Chamadas por arquivo	Tokens de entrada por arquivo	Tokens de saída por arquivo	Segundos de chamada por arquivo	Tokens por issue real acusada
B0	2	3.294	2.447	158	43.632
B1	1	1.193	353	23	16.020
C1	3	4.090	1.373	54	155.689
C2	5	8.133	3.944	197	344.205
C3	3,4	4.883	1.728	72	188.415

GPU: execução principal 9,7 h; extração das respostas do artigo nos negativos 1,03 h; variância 3,94 h; C3-mf 0,76 h; A3b no B0 2,17 h. Total: 17,6 h, mais ~3,4 h de piloto e ajustes.

Apêndice C · Testes pareados por local

Teste	Issues reais (56 locais)	Falsos alarmes conhecidos (85 locais)
Q de Cochran (5 configurações)	$Q = 28{,}4$ (gl 4), $p = 1{,}0 \times 10^{-5}$	$Q = 65{,}0$ (gl 4), $p = 2{,}6 \times 10^{-13}$
McNemar B1 × C3	7 só no B1, 0 só no C3: p = 0,016 (Holm 0,11)	11 contra 0: p = 0,001 (Holm 0,007)
McNemar B0 × B1	8 contra 4: p = 0,39	12 contra 2: p = 0,013 (Holm 0,052)
McNemar C2 × C3	1 contra 1: p = 1	0 contra 0: p = 1
Fisher (o que o verificador manteve)	4 de 11 reais	2 de 13 falsos: p = 0,36

Apêndice D · Auditoria completa

Item	Veredito
Tabela 11 (GPT-4o, 2024): o texto diz 17 corrigidas e 15 não; a tabela tem 16 e 16	confirmado
Tabelas 17 e 18 (código do usuário × gerado): 3 de 6 células divergem da recontagem	confirmado
Finding 15 (“todos os modelos vão melhor em código do usuário”)	refutado (GPT-4.1, Opus)
“GPT-5 corrigiu todas as 44 issues que detectou”: as 44 corrigidas não são as mesmas	refutado
O gabarito mudou entre 2024 e 2025 no mesmo snapshot (4 saíram; 2 com metadados alterados)	confirmado
“Melhora” de 2024 para 2025: McNemar exato nos 28 itens comuns, p = 0,065 a 0,267	não significativa
“Re-scanning of the modified code” no resumo × reescaneamento como trabalho futuro	inconsistência
Número de scanners (texto diz 3, o estudo usa 4); 49 das 56 issues vêm de um só scanner	inconsistência
“Accuracy” nos Findings 4 e 15 é recall relativo, sem precisão nem falso positivo	rótulo inadequado
CWEs trocadas na Tabela 14 (v10:3/7 e v10:3/11)	confirmado



Centro de Informática

UFPE